

SIMATS ENGINEERING
ASSESSMENT TOOL III – Penetration testing Task

Course:	Code:	CO: CO3
Duration: 90 min	Total Marks: 50	Reg No : 192424293 Name : C Prathibha

COURSE OUTCOME COVERED

***CO3:** Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.(BL4)*

Duration: 90 min

Instructions: Answer all questions. Each question carries 10 marks.

- 1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the theHarvester tool against the authorized domain tesla.com, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases. Required Tool: theHarvester.**

Objective :

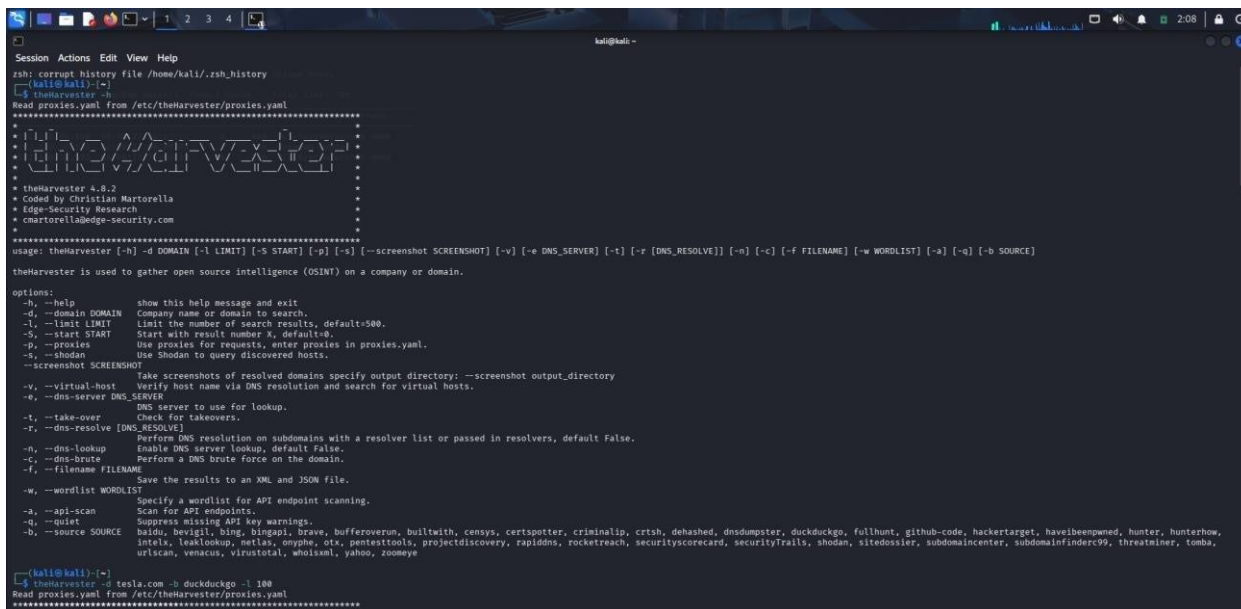
To perform passive reconnaissance on the authorized domain **tesla.com** using theHarvester and identify publicly available hosts, subdomains, IP addresses, email addresses, and other infrastructure information.

Tool Used

- **Tool:** theHarvester
- **Version:** 4.8.2
- **Target:** tesla.com
- **Type:** Passive Reconnaissance / OSINT **Command Help and Tool Options**

First, theHarvester help command was used to understand the available options and search sources.

Command Used : theHarvester -h



```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
*****
theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* martorell@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN   Company name or domain to search.
  -l, --limit LIMIT      Limit the number of search results, default=500.
  -s, --start START      Start with result number s, default=0.
  -p, --proxies          Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan          Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -v, --virtual-host     Verify host name via DNS resolution and search for virtual hosts.
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over       Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup      Enable DNS server lookup, default False.
  -c, --dns-brute       Perform a DNS brute force on the domain.
  -f, --filename FILENAME Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST Specify a wordlist for API endpoint scanning.
  -a, --api-scan        Scan for API endpoints.
  -q, --quiet           Suppress missing API key warnings.
  -b, --source SOURCE   baidu, devigil, Bing, Bingapi, brave, bufferoverun, builtwith, censys, certspotter, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, fullhunt, github-code, hackertarget, haveibeenpwned, hunter, hunterhow, intelx, leaklookup, setlist, onyphe, otc, pentesttools, projectdiscovery, rapiddns, rocketreach, securityscorecard, securityTrails, shodan, sitedossier, subdomaincenter, subdomainfinder99, threatminer, tomba, urlscan, venacms, virustotal, whoisxml, yahoo, zoomeye

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
```

Observation

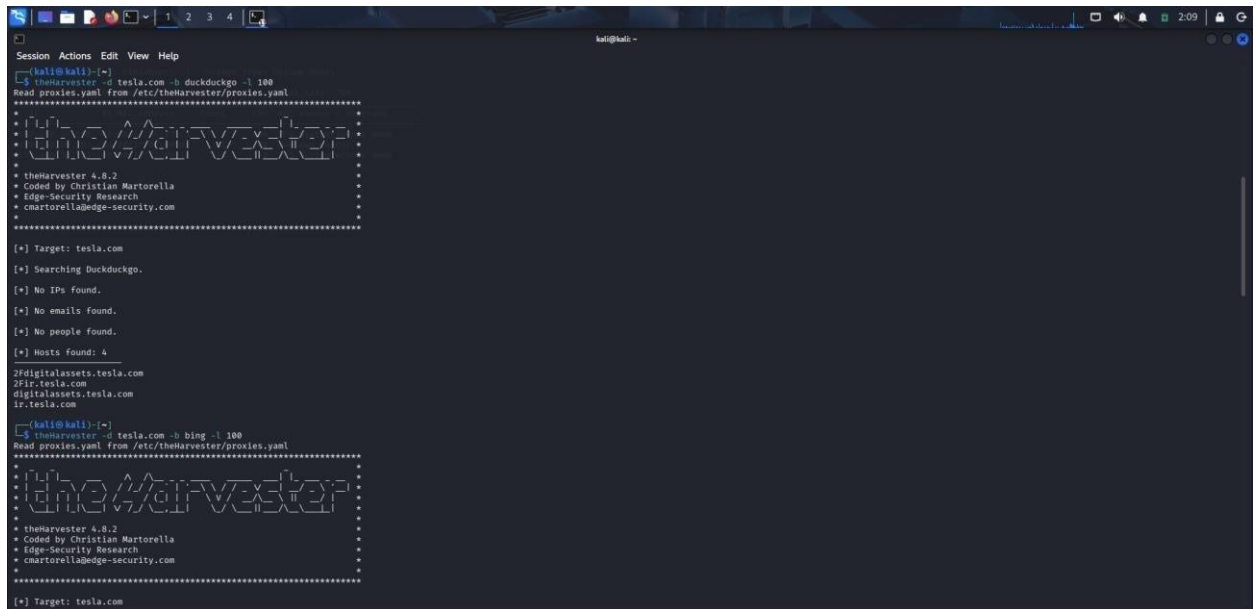
The help output shows that theHarvester can collect publicly available information such as hosts, IP addresses, email addresses, people, and other domain-related information using different search sources.

Reconnaissance Using DuckDuckGo

The first passive reconnaissance search was performed using DuckDuckGo with a limit of 100 results.

Command Used : theHarvester -d tesla.com -b duckduckgo -l 100 **Where:**

- -d tesla.com : Specifies the target domain.
- -b duckduckgo : Uses DuckDuckGo as the search source.
- -l 100 : Limits the number of search results.



```
kali@kali:~$ theHarvester -d tesla.com -b duckduckgo -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.8.2 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****

[*] Target: tesla.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4

2Fdigitalassets.tesla.com
2Fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

kali@kali:~$ theHarvester -d tesla.com -b bing -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.8.2 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****

[*] Target: tesla.com
```

Observation

The DuckDuckGo search identified **4 hosts**:

1. 2Fdigitalassets.tesla.com
2. 2Fir.tesla.com
3. digitalassets.tesla.com
4. ir.tesla.com

Reconnaissance Using Bing

A second passive search was performed using Bing.

Command Used : theHarvester -d tesla.com -b bing -l 100

```
Session Actions Edit View Help
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****
[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
  Searching @ results.
[*] Searching Bing.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 1
shop.tesla.com

(kali@kali)~$ theHarvester -d tesla.com -b crtsh -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
theHarvester 4.8.2
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com
*****
[*] Target: tesla.com
An exception has occurred: 502, message='Attempt to decode JSON with unexpected mimetype: text/html', url='https://crt.sh/?q=X25.tesla.com&exclude=expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

Observation

- The Bing search identified **1 host** : shop.tesla.com
- No IP addresses, email addresses, or people were found.

Combined Search Using Multiple Sources

To obtain broader passive reconnaissance results, multiple sources were searched together.

Commands Used :

- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon

```
Se Firefox ESR Browse the World Wide Web

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
theHarvester 4.8.2
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com
*****
[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
  Searching @ results.
[*] Searching Bing.
An exception has occurred: 404, message='Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1', url='https://crt.sh/?q=X25.tesla.com&exclude=expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2fdigitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
```

Observation : The combined search produced the following results:

- IPs found: 0
- Emails found: 0
- People found: 0
- Hosts found: 4

```

kali@kali: ~
[+] No people found.
[+] Hosts found: 4
2fdigitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

kali@kali: ~
theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon
Read proxies.yaml from /etc/theHarvester/proxies.yaml
=====
  theHarvester
=====
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorell@edge-security.com
=====

[+] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
  Searching 0 results.
[+] Searching Bing.
[+] Searching Duckduckgo.
An exception has occurred: 404, message: Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1, url: https://crt.sh/?q=%25.tesla.com&exclude=expired&deduplicate=Y&output=json
[+] Searching crtsh.

[+] No IPs found.
[+] No emails found.
[+] No people found.
[+] Hosts found: 4
2fdigitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

[+] Reporting started.
[+] XML File saved.
[+] JSON File saved.

```

Security Analysis

- The reconnaissance identified **5 hostnames** across the DuckDuckGo and Bing searches.
- No IP addresses or email addresses were identified in the selected search results.
- No direct employee-information exposure was identified during this exercise.
- The results alone do **not** prove that any of the discovered hosts are vulnerable.
- The crt.sh source could not be successfully queried because it returned HTTP errors.

Risk and Recommendations

- Unused or unnecessary subdomains should be removed.
- Organizations should maintain an updated inventory of externally exposed assets.
- Publicly accessible hostnames should be reviewed regularly.
- Unnecessary information disclosure should be minimized.
- Externally accessible services should be checked during authorized security testing.

Conclusion

TheHarvester was successfully used to perform passive reconnaissance on tesla.com. The assessment identified 5 publicly visible hostnames from the available search results. No IP addresses, email addresses, or people were identified.

The crt.sh source returned HTTP errors and therefore did not provide usable results during the assessment. The final reconnaissance was successfully saved in XML and JSON formats for further analysis.

2. **During a penetration-testing engagement, assess the publicly accessible web application testphp.vulnweb.com using the Nikto tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. Required Tool: Nikto.**

Objective:

To assess an authorized vulnerable web server using Nikto and identify outdated software, information disclosure, missing security headers, and configuration weaknesses.

Target: 192.168.56.102 - Metasploitable 2

Tool: Nikto 2.5.0

Protocol: HTTP/80

Commands Used

- ping -c 4 192.168.56.102
- curl -I http://192.168.56.102
- nikto -h <http://192.168.56.102>

```
kali@kali:~$ ip route
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
172.17.0.0/24 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
192.168.56.0/24 dev eth1 proto kernel scope link src 192.168.56.101 metric 101

kali@kali:~$ ip neigh show 192.168.56.102
192.168.56.102 dev eth1 lladdr 08:00:27:73:fb:10 STALE

kali@kali:~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=5.40 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=0.11 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=211 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=3.45 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3043ms
rtt min/avg/max/mdev = 3.448/56.688/211.401/89.420 ms

kali@kali:~$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2020 06:56:18 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

kali@kali:~$ nmap -sV http://192.168.56.102
Nmap v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2020-08-11 03:49:42 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc39d15,ht-tps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.

inet addr:192.168.56.102 Bcast:192.168.56.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:2148 errors:0 dropped:0 overruns:0 frame:0
TX packets:1268 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:177874 (173.7 KB) TX bytes:92200 (90.0 KB)
Base address:0xd020 Memory:f0200000-f0220000

msfadmin@metasploitable:~$ ping -c 192.168.56.101
Usage: ping [-LRUbdfnqrwVaaA] [-c count] [-i interval] [-w deadline]
        [-p pattern] [-s packetsize] [-t ttl] [-I interface or address]
        [-M mtu discovery hint] [-S sndbuf]
        [-T timestamp option] [-Q tos] [hop1 ...] destination

msfadmin@metasploitable:~$ ping -c 4 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=2.20 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=1.41 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=245 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=1.99 ms

--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3002ms
rtt min/avg/max/mdev = 1.410/62.830/245.713/105.587 ms
msfadmin@metasploitable:~$
```

Findings

- Apache/2.2.8 detected - outdated component (High).
- PHP/5.2.4 detected - outdated component (High).
- Apache and PHP versions are disclosed (Medium).
- X-Frame Options is missing (Medium).
- X-Content Type Options is missing (Low - Medium).
- Apache MultiViews is enabled (Medium).
- Uncommon tcn header detected (Manual validation required).

Recommendations

Upgrade Apache and PHP, hide unnecessary version information, configure security headers, disable MultiViews if unnecessary, and investigate unusual headers. Re-run Nikto after remediation.

Conclusion:

Nikto successfully identified multiple security weaknesses in the authorized Metasploitable web server, with outdated Apache and PHP being the highest-priority issues.

- 3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the Dig utility against the authorized target domain zonetransfer.me, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. Required Tool: Dig.**

Objective

To perform DNS enumeration of the authorized domain zonetransfer.me using the Dig utility, identify available DNS records and authoritative name servers, and determine whether an unauthorized DNS zone transfer (AXFR) is permitted.

Tool Used

Tool : Dig

Target : zonetransfer.me

Platform : Kali Linux

Procedure

1. The following DNS queries were performed:

- dig zonetransfer.me

dig zonetransfer.me NS dig

zonetransfer.me SOA

- dig zonetransfer.me A
- dig zonetransfer.me AAAA
- dig zonetransfer.me MX
- dig zonetransfer.me CNAME
- dig zonetransfer.me TXT

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ dig -v
Dig 9.20.15-2-Debian
kali@kali:~$ dig zonetransfer.me
; <>> Dig 9.20.15-2-Debian <>> zonetransfer.me
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 65482
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1232
; COOKIE: 56a9e0c1f38a1cd (echoed)
;; QUESTION SECTION:
;zonetransfer.me.          IN      A
;; Query time: 16 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Aug 11 06:09:18 EDT 2020
;; MSG SIZE rcvd: 56

kali@kali:~$ dig zonetransfer.me NS
; <>> Dig 9.20.15-2-Debian <>> zonetransfer.me NS
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 9717
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1232
; COOKIE: 5086195628ae98a (echoed)
;; QUESTION SECTION:
;zonetransfer.me.          IN      NS
;; Query time: 36 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Aug 11 06:09:29 EDT 2020
;; MSG SIZE rcvd: 56

kali@kali:~$ dig zonetransfer.me SOA
```

```
Session Actions Edit View Help
kali@kali:~$ dig zonetransfer.me AAAA
; <>> Dig 9.20.15-2-Debian <>> zonetransfer.me AAAA
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 49573
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1232
; COOKIE: 03a06e5dd532b (echoed)
;; QUESTION SECTION:
;zonetransfer.me.          IN      AAAA
;; Query time: 136 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Aug 11 06:10:03 EDT 2020
;; MSG SIZE rcvd: 56

kali@kali:~$ dig zonetransfer.me MX
; <>> Dig 9.20.15-2-Debian <>> zonetransfer.me MX
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 52292
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1232
; COOKIE: 55109ae7076a2cc5 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.          IN      MX
;; Query time: 124 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Aug 11 06:10:35 EDT 2020
;; MSG SIZE rcvd: 56

kali@kali:~$ dig zonetransfer.me CNAME
; <>> Dig 9.20.15-2-Debian <>> zonetransfer.me CNAME
;; global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 44744
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
```

2. The authoritative servers were then tested for zone transfer:

- dig AXFR zonetransfer.me @nsztm1.digi.ninja
- dig AXFR zonetransfer.me @nsztm2.digi.ninja

- Mail infrastructure
- Host naming conventions
 - VPN-related hosts
 - Office infrastructure
- Internal DNS names.

Recommendations

- Restrict AXFR/IXFR to authorized secondary DNS servers.
- Use TSIG or another suitable authentication mechanism for zone transfers.
- Prevent unauthorized external systems from requesting zone transfers.
- Separate internal and external DNS information.
- Remove obsolete and unnecessary DNS records.
- Monitor and log unexpected AXFR requests.

Conclusion

The DNS assessment successfully identified the authoritative servers and demonstrated that AXFR was permitted from both tested servers. Each server returned 52 records, exposing various hostnames, IP addresses, mail infrastructure and service-related information. The assessment demonstrates the reconnaissance risk associated with unrestricted DNS zone transfers and highlights the importance of restricting AXFR access to trusted DNS infrastructure.

- 4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target 192.168.1.100 using Enum4linux to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operatingsystem details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB**

shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation.

Required Tool: Enum4linux.

Objective :

To perform authorized enumeration of a Windows SMB target using Enum4linux and identify users, groups, shared resources, workgroup information, NetBIOS details, password-policy information, and exposed SMB configuration details.

Target and Tools

Target : 192.168.56.102

Tester : Kali Linux

Required tool : Enum4linux v0.9.1

Supporting tools : Nmap, smbclient

Network : Isolated VirtualBox Host-Only network

Commands Used

- `nmap -Pn -p 139,445 192.168.56.102`
- `enum4linux -a 192.168.56.102`
- `enum4linux -U 192.168.56.102`
- `enum4linux -G 192.168.56.102`
- `enum4linux -S 192.168.56.102`

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ nmap -p 139,445 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-11 06:36 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0007s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 0A:00:27:00:00:0A (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds

kali@kali:~$ enumlinux -a 192.168.56.102
Starting enumlinux v0.9.1 ( http://labs.portcullis.co.uk/application/enumlinux/ ) on Tue Aug 11 06:36:29 2020

( Target Information )
Target ..... 192.168.56.102
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.56.102 )

[*] Got domain/workgroup name: WORKGROUP

( Nbtstat Information for 192.168.56.102 )

Looking up status of 192.168.56.102
JAHNAVI <20> - M <ACTIVE> File Server Service
JAHNAVI <00> - M <ACTIVE> Workstation Service
WORKGROUP <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
MAC Address = 0A-00-27-00-00-0A

( Session Check on 192.168.56.102 )

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

kali@kali:~$ smbclient -L //192.168.56.102 -U "Jahnavi kodavati"
Password for [WORKGROUP\Jahnavi kodavati]:
```

```
Session Actions Edit View Help
kali@kali:~$ smbclient -L //192.168.56.102 -U "Jahnavi kodavati"
Password for [WORKGROUP\Jahnavi kodavati]:

Sharename      Type            Comment
-----
ADMIN$         Disk            Remote Admin
C$             Disk            Default share
IPC$          IPC             Remote IPC
Reconnecting with SMB1 for workgroup listing:
do_connect: Connection to 192.168.56.102 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

kali@kali:~$ enumlinux -u 192.168.56.102
Starting enumlinux v0.9.1 ( http://labs.portcullis.co.uk/application/enumlinux/ ) on Tue Aug 11 06:41:07 2020

( Target Information )
Target ..... 192.168.56.102
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.56.102 )

[*] Got domain/workgroup name: WORKGROUP

( Session Check on 192.168.56.102 )

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

kali@kali:~$ enumlinux -G 192.168.56.102
Starting enumlinux v0.9.1 ( http://labs.portcullis.co.uk/application/enumlinux/ ) on Tue Aug 11 06:41:20 2020

( Target Information )
Target ..... 192.168.56.102
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

SMB Port Findings

1. Nmap identified :

- 139/tcp OPEN netbios-ssn
- 445/tcp OPEN microsoft-ds

2. Workgroup and NetBIOS Findings

Enum4linux identified:

- <20> - File Server Service
- <00> - Workstation Service

These details were successfully obtained through NetBIOS enumeration.

3. Anonymous/Null-Session Testing

Enum4linux attempted to establish an unauthenticated session using an empty username and password. The target rejected the request:

- Server doesn't allow session using username "", password "".
- The same restriction prevented anonymous user, group, and share enumeration.
- Assessment: Anonymous/null-session enumeration was not permitted.

4. Authenticated SMB Share Enumeration

- Using the authorized Windows account, the following shares were identified:
- These shares were returned after successful authenticated SMB access.

5. Windows Account Findings

- The local accounts identified during the assessment were : Administrator , DefaultAccount
- This means compromise of that account could potentially provide administrative control of the workstation.

Security Analysis

- From an attacker's perspective, the collected information provides useful reconnaissance:
- SMB availability identifies a Windows system offering file-sharing services.
- NetBIOS and workgroup information helps identify the host and its network role.
- Local account information provides potential username targets.
- Administrative group membership identifies a highly privileged account.
- SMB administrative shares may become valuable if valid credentials are compromised.
- Weak password-policy settings can increase the risk of credential attacks.

Recommendations

- Restrict SMB access using host/network firewall rules.
- Disable unnecessary SMB services and legacy SMB1.
- Maintain strict share and NTFS permissions.
- Review local administrator memberships and remove unnecessary accounts.
- Enforce a strong minimum password length.
- Enable appropriate password history.

Conclusion

The assessment successfully demonstrated SMB and NetBIOS enumeration against the authorized Windows target. SMB ports 139 and 445 were accessible, and WORKGROUP, JAHNAVI, and standard administrative SMB shares were identified. Anonymous/null-session enumeration was correctly blocked. Authenticated enumeration exposed administrative shares and confirmed privileged local-account membership. The primary security improvements are stronger password controls, least-privilege administration, SMB exposure restrictions, and continued Windows patching.

5. During an external penetration-testing engagement, assess the authorized target `scanme.nmap.org` using Netcat (`nc`) to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. Required Tool: Netcat (`nc`).

Netcat External Service Assessment

Objective :

To assess the authorized target scanme.nmap.org using Netcat and identify accessible TCP services, banners, software versions, and security-relevant information disclosure.

Domain: scanme.nmap.org

IP: 45.33.32.156

Tool: Netcat (nc)

Platform: Kali Linux

Commands Used

- ping -c 4 scanme.nmap.org
- nc -vz scanme.nmap.org 22
- nc -v 45.33.32.156 22
- nc -vz scanme.nmap.org 80
- nc -v 45.33.32.156 80
- nc -vz scanme.nmap.org 53
- nc -vz scanme.nmap.org 9929
- nc -v 45.33.32.156 9929

```
Session / Terminal Emulator
Use the command line

zsh: correct history file from ~/.zsh_history
(kali@kali)~$ nc -h
[v1.10-50.1]
connect to somewhere: nc [-options] hostname port[s] [ports] ...
listen for inbound: nc -l -p port [-options] [hostname] [port]
options:
  -c shell commands          as "-s" use /bin/sh to exec [dangerous!!]
  -e filename                program to exec after connect [dangerous!!]
  -b                          allow broadcasts
  -g gateway                 source-routing hop point[s], up to 8
  -G num                     source-routing pointer: 4, 8, 12, ...
  -h                          this cruft
  -i secs                    delay interval for lines sent, ports scanned
  -I                          set keepalive option on socket
  -l                          listen mode, for inbound connects
  -n                          numeric-only IP addresses, no DNS
  -o file                    hex dump of traffic
  -p port                    local port number
  -P                          randomize local and remote ports
  -q secs                    quit after EOF on stdin and delay of secs
  -s addr                    local source address
  -T tos                      set Type Of Service
  -t                          answer TELNET negotiation
  -u                          UDP mode
  -v                          verbose [use twice to be more verbose]
  -w secs                    timeout for connects and final net reads
  -c                          Send CRLF as line-ending
  -Z                          zero-I/O mode (used for scanning)
  -z                          zero-I/O mode (used for scanning)
port numbers can be individual or ranges: lo-hi [inclusive];
hyphens in port names must be backslash escaped (e.g. 'ftp-data').

(kali@kali)~$ ping -c 4 scanme.nmap.org
PING scanme.nmap.org (45.33.32.156) 56(84) bytes of data:
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=1 ttl=255 time=474 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=2 ttl=255 time=406 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=3 ttl=255 time=416 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=4 ttl=255 time=338 ms

--- scanme.nmap.org ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 4120ms
rtt min/avg/max/mdev = 338.003/408.143/474.295/48.320 ms

(kali@kali)~$ nc -vz scanme.nmap.org 22
scanme.nmap.org [45.33.32.156] 22 (ssh) open

(kali@kali)~$ nc -v scanme.nmap.org 22
Can't parse scanme.nmap.org as an IP address
```

```
Session Actions Edit View Help

(kali@kali)~$ nc -v 45.33.32.156 22
scanme.nmap.org [45.33.32.156] 22 (ssh) open
SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13

(kali@kali)~$ nc -vz scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

(kali@kali)~$ nc -vz scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

(kali@kali)~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
GET / HTTP/1.1
Host: scanme.nmap.org
Connection: close
Date: Wed, 12 Aug 2020 05:22:15 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h2>400 Bad Request</h2>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>
</body></html>

(kali@kali)~$ nc -v scanme.nmap.org 80
Connection: close
Connection: command not found

(kali@kali)~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
HEAD / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Wed, 12 Aug 2020 05:26:23 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Content-Type: text/html; charset=iso-8859-1
```

```
kali@kali: ~  
Session Actions Edit View Help  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>400 Bad Request</title>  
</head><body>  
<h1>Bad Request</h1>  
<p>Your browser sent a request that this server could not understand.<br />  
</p>  
<hr />  
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>  
</body></html>  
[kali@kali]~  
$ curl -v 45.33.32.156 80  
scanme.nmap.org [45.33.32.156] 80 (http) open  
HEAD / HTTP/1.1  
HTTP/1.1 400 Bad Request  
Date: Wed, 12 Aug 2020 05:24:23 GMT  
Server: Apache/2.4.7 (Ubuntu)  
Content-Length: 286  
Connection: close  
Content-Type: text/html; charset=iso-8859-1  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>400 Bad Request</title>  
</head><body>  
<h1>Bad Request</h1>  
<p>Your browser sent a request that this server could not understand.<br />  
</p>  
<hr />  
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>  
</body></html>  
[kali@kali]~  
$ nc -v scanme.nmap.org 53  
scanme.nmap.org [45.33.32.156] 53 (domain) : Connection refused  
[kali@kali]~  
$ nc -v scanme.nmap.org 9929  
scanme.nmap.org [45.33.32.156] 9929 (?) open  
[kali@kali]~  
$ nc -v 45.33.32.156 9929  
scanme.nmap.org [45.33.32.156] 9929 (?) open  
[kali@kali]~  
$
```

Observations

- Target IP: 45.33.32.156
- Ping: 4/4 received, 0% packet loss
- 22/TCP: Open - SSH
- SSH banner: OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
- 80/TCP: Open - HTTP
- HTTP banner: Apache/2.4.7 (Ubuntu)
- 53/TCP: Connection refused
- 9929/TCP: Open - binary response, service not identified

Banner:

SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13

This reveals the SSH protocol, OpenSSH version, and Ubuntu platform information. It assists attacker fingerprinting and vulnerability research. This is primarily an information disclosure, not proof of a vulnerability. The actual installed package and patch status should be validated.

HTTP Finding :

Response included:

- HTTP/1.1 400 Bad Request

- Server: Apache/2.4.7 (Ubuntu)
- Content-Type: text/html; charset=iso-8859-1
- The server reveals Apache version and Ubuntu information. This assists fingerprinting and vulnerability research. The 400 response itself is not a vulnerability.

TCP/9929

- The port was open and returned binary/non-printable data. Netcat could not identify the service or version. Further authorized validation is required.

Remediation

- Keep Internet-facing software patched.
- Restrict unnecessary services.
- Restrict SSH access where possible.
- Minimize unnecessary version/banner disclosure.
- Monitor externally exposed ports.
- Periodically reassess the external attack surface.

Conclusion

Netcat successfully identified accessible TCP services and useful service-banner information. SSH and HTTP exposed software/version information that could assist attacker fingerprinting. These findings should primarily be treated as information disclosure, with further validation required to establish actual vulnerabilities.

Code of Conduct:

I C Prathibha - 192424293 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: C Prathibha

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Task	20				
Procedure & Execution	25				
Observation & Result	20				
Viva Voce / Conceptual Response	20				
Time Management & Presentation	15				

Criteria	Understanding of Task	Procedure Execution	Observation Result	Viva Voce / Conceptual Response	Time Management & Presentation
Weightage	20 (2)	25 (3)	20 (2)	20 (2)	15 (1)
Q1					
Q2					
Q3					
Q4					
Q5					